▶ 1분 미리보기

Chapter 2. Bedrock 위에서 안전하게 쓰기

키는 나눠 주지 않고, 정책은 파일로, 막을 것은 앞에서 (Claude Code v2.1.319, Bedrock 기준)

Oh, Junseok
Sr. Solutions Architect
AWS Korea

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

핵심은 강의, 깊이는 실습

세 개의 Part, 연결에서 정책과 가드레일까지

PART 01

Bedrock에 연결하기

환경변수 두 개, SSO 로그인, 모델 고정과 팀별 비용

PART 02

정책은 파일로

managed settings, 우선순위, /status로 확인

PART 03

무엇을 못 하게 할 것인가

deny가 이긴다, 훅은 exit 2, DLP 다섯 겹, 남는 기록

LAB / Ch2 Lab 1

정책 배포, managed settings와 게이트웨이 그룹 정책

정책을 배포하고, 개인 설정으로 우회가 안 되는지 확인

LAB / Ch2 Lab 2

가드레일과 DLP, 훅과 auto mode

훅을 만들고 직접 뚫어 본 뒤 고치기

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

금융권이 Bedrock을 고르는 이유

대신 claude.ai의 관리 콘솔, Analytics, 정책 서버가 없음

01

계정 경계 안의 추론

처리 리전은 추론 프로필 범위를 따름 (global은 리전 밖 처리 가능)

02

기존 통제의 재사용

IAM, IAM Identity Center, CloudTrail, Organizations

03

청구 일원화

AWS 청구서와 Cost Explorer, Budgets로 관리

04

빈자리는 직접 채움

정책은 파일과 MDM으로, 관측은 OTel(OpenTelemetry)로

claude.ai의 관리 콘솔, Analytics, 정책 서버가 없는 자리를 무엇으로 채우는지, 그것이 이 챕터와 Ch6의 이야기입니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CHAPTER 02 / PART 01

Bedrock에 연결하기

첫 세션까지 가장 짧은 길

01
환경변수 두 개

02
SSO로 로그인

03
모델 고정과 팀별 비용

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

환경변수 두 개로 연결

수동 설정과 리전 결정 순서

```
# Bedrock 사용
export CLAUDE_CODE_USE_BEDROCK=1
# 프로필에 리전이 없을 때만 (서울 리전 예시)
export AWS_REGION=ap-northeast-2
# 사내 엔드포인트, 게이트웨이를 쓸 때
# export ANTHROPIC_BEDROCK_BASE_URL=https://...
```

~/.zshrc 또는 settings.json의 env에 둡니다.

이번 세션의 리전

ap-northeast-2

1. AWS_REGION

다음 경우 보기

리전 결정 순서 (위가 먼저). 줄을 눌러 값을 넣고 빼 보세요.
값은 예시입니다.

1	AWS_REGION	ap-northeast-2
2	AWS_DEFAULT_REGION	us-west-2
3	활성 프로필의 region	us-east-1
4	기본값	us-east-1

/status에서 리전이 어디서 왔는지 출처까지 확인합니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

다섯 가지 중 권장은 하나

Bedrock API 키만 AWS SDK 기본 체인을 거치지 않음

AWS CLI 설정	`aws configure`	비권장 (장기 키 디스크 저장)
액세스 키 환경변수	`AWS_ACCESS_KEY_ID` 등	비권장 (장기 키)
SSO 프로필	`aws sso login + AWS_PROFILE`	권장
콘솔 자격증명	`aws login`	보조 수단
Bedrock API 키	`AWS_BEARER_TOKEN_BEDROCK`	비권장 (장기 키)

권장입니다. SSO 로그인으로 짧은 수명의 자격증명을 받습니다.

만료되면 다음 장의 자동 갱신으로 이어 갑니다.

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

만료 시 자동 재로그인

SSO 자동 갱신, awsAuthRefresh와 awsCredentialExport

STEP 1 **세션 시작: SDK 체인으로 찾습니다**

Claude Code는 **AWS SDK 기본 체인**으로 자격증명을 찾고, **만료 5분 전까지 메모리에 캐시**합니다. 체인 해석에는 **60초 타임아웃**이 있습니다.



설정 한 장

~/.claude/settings.json

```
{
  "awsAuthRefresh": "aws sso login --profil
e myprofile",
  "env": {
    "AWS_PROFILE": "myprofile"
  }
}
```

AWS_PROFILE로 **SSO 프로필**을 가리킵니다.

- AWS SDK 기본 체인
- 만료 5분 전까지 메모리 캐시
- 체인 해석 60초 타임아웃

● Claude Code ● 자격증명 흐름 ● 갱신 명령 ● 문제 상황

‹ 1 / 4 ›

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

고정하지 않으면 무엇이 도는가?

QUICK CHECK, 손을 들어 답해 주세요

모델을 고정하지 않은 Bedrock 배포에서 기본 주 모델은?

A Sonnet 4.5

B Opus 5.5

C Haiku 5.5

D Sonnet 5.5

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

여러 사용자에게 배포하면 반드시 고정

ANTHROPIC_DEFAULT_*와 리전에 따른 prefix 규칙

```
# managed settings env, 이 랩: us-east-1, global 프로필
ANTHROPIC_DEFAULT_OPUS_MODEL=global.anthropic.claude-opus-5-5
ANTHROPIC_DEFAULT_SONNET_MODEL=global.anthropic.claude-sonnet-5-5
ANTHROPIC_DEFAULT_HAIKU_MODEL=global.anthropic.claude-haiku-5-5

# 고정 대신 prefix만 바꾸기
ANTHROPIC_BEDROCK_REGION_PREFIX=global
```

허용값: us, eu, apac, jp, au, global. 계정에 있는 profile ID로 채웁니다.

리전을 고르면 prefix가 바뀝니다.

us-* → **us.**	eu-* → **eu.**
ap-* (서울 포함) → **apac.**	그 외 → **global.**

이 랩은 us-east-1에서 global 프로필을 씁니다.
리전 그룹을 고르면 왼쪽 prefix가 바뀝니다.
바뀐 ID는 예시이며, 실제 값은 계정에 있는 profile ID로 확인합니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

팀별 비용의 기준, 프로필 ARN

Application inference profile로 경로와 비용 경계를 고정

STEP 1 **팀마다 프로필을 하나 만듭니다**

원본 프로필을 **copyFrom**으로 복사해 팀 이름과 **태그**를 단 Application inference profile을 만듭니다.



프로필 만들기

Terminal

```
aws bedrock \
  create-inference-profile \
  --inference-profile-name \
    sonnet-team-a \
  --model-source copyFrom=\
arn:aws:bedrock:us-east-1:
<ACCOUNT>:inference-profile/
global.anthropic.claude-sonnet-5-5 \
  --tags key=team,value=team-a \
    key=costcenter,value=1234
```

ARN은 화면 폭 때문에 나눠 적었습니다. 실제로는 한 줄입니다. 만든 ARN을 다음 단계에서 managed settings에 연결합니다.

- 원본 프로필을 그대로 따름
- 태그: team, costcenter
- 팀마다 프로필 하나

● 만들기 ● 프로필 ● 정책과 선택 ● 비용 보기

‹ 1 / 3 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CHAPTER 02 / PART 02

정책은 파일로

콘솔이 없으니 파일이 정책이다

01
managed settings 파일

02
키 충돌 시 상위 우선

03
/status로 확인

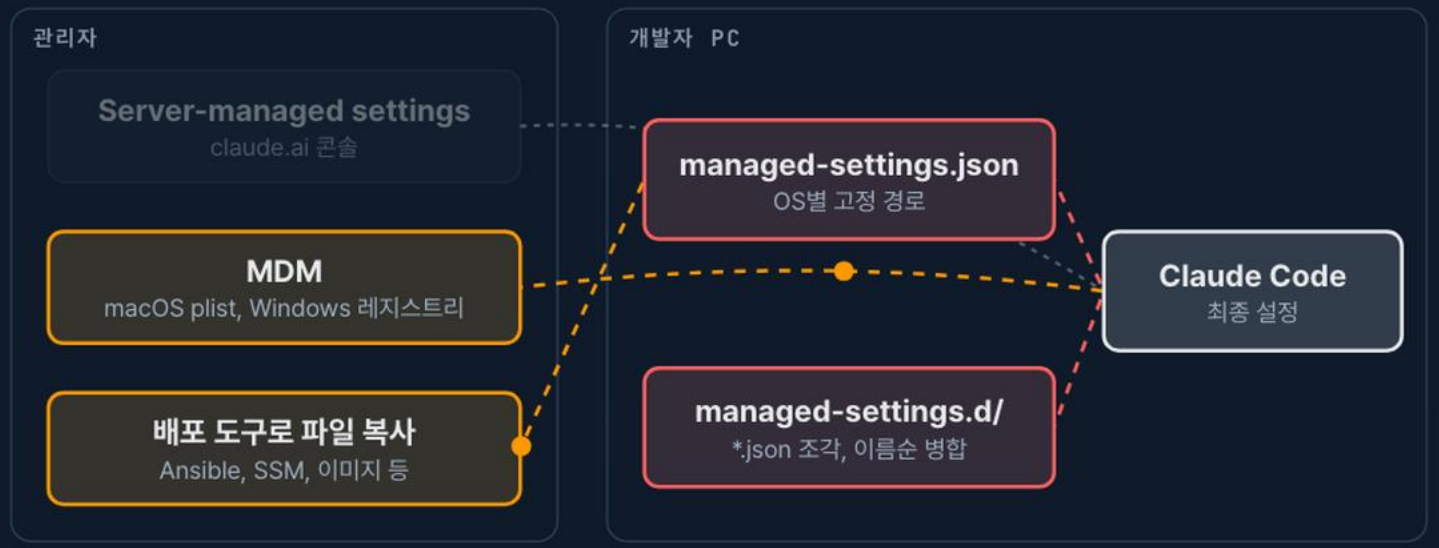
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

콘솔 대신 파일과 MDM

Bedrock에서 정책이 도달하는 길과 병합 규칙

OVERVIEW **세 갈래 중 두 갈래만 열려 있습니다**

claude.ai 콘솔의 **Server-managed settings는 Bedrock에서 쓸 수 없습니다**. 대신 **파일과 MDM**으로 정책을 내려보냅니다.



● 배포 채널 ● 사용자가 못 바꾸는 파일 ● 적용 결과 ● Bedrock에서 쓸 수 없음

정책이 닿는 곳

Bedrock 경로

```
# 쓸 수 없음
Server-managed settings (claude.ai 콘솔)

# 쓸 수 있음
managed-settings.json (OS별 경로)
MDM: macOS plist, Windows 레지스트리
```

점선은 Bedrock 경로에서 쓸 수 없는 길입니다.

- 쓸 수 없음: 서버 관리 설정
- 쓸 수 있음: OS별 정책 파일
- 쓸 수 있음: MDM (plist, 레지스트리)

‹ 1 / 6 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

키 충돌 시 상위 우선

설정 우선순위 다섯 층, 값을 넣어 보며 확인

1	Managed	파일, MDM. 사용자가 덮어쓸 수 없음 managed-settings.json	sonnet
2	CLI 인자	이번 세션에만 적용 --settings	haiku
3	Local	개인, 커밋하지 않음 .claude/settings.local.json	opus
4	Project	팀 공유, 저장소에 커밋 .claude/settings.json	sonnet
5	User	내 PC의 모든 프로젝트 ~/.claude/settings.json	opus

이번 세션의 모델 (예시 키)

sonnet

1. Managed가 이김

다음 경우 보기

줄을 눌러 그 층에 값을 넣고 빼 보세요. 오른쪽 값은 설명용 예시입니다.

다섯 층에 모두 값이 있으면 Managed가 이깁니다. 아래 어떤 층도 덮어쓰지 못합니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

배포 이후가 진짜 시작

적용 검증 4단계

1

/status 확인

Setting sources에 Enterprise managed settings가 보이는지

2

덮어쓰기 실패 확인

~/.claude/settings.json에서 같은 키를 바꿔도 적용되지 않는지

3

모델 선택 확인

/model에 허용한 모델만 보이는지

4

차단 규칙 확인

.env 읽기를 요청했을 때 거부되는지

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CHAPTER 02 / PART 03

무엇을 못 하게 할 것인가

앞에서 막고, 못 막은 것은 기록으로

01
deny 절대 우선

02
훅은 exit 2만 차단

03
DLP 다섯 겹과 남는 기록

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

142명 중 51명이 고른 주제

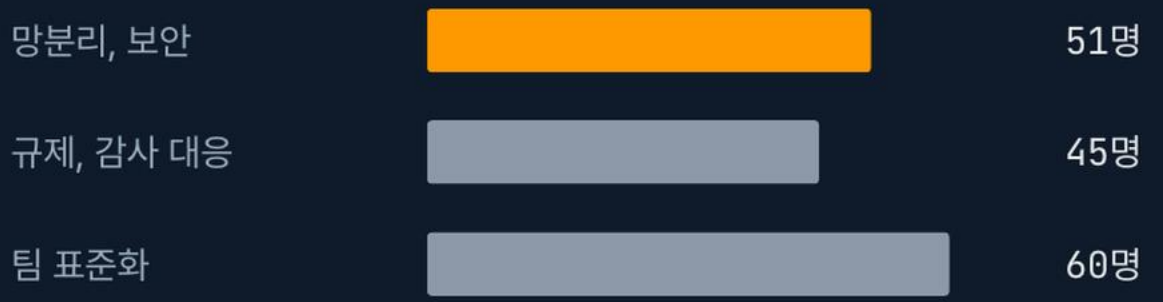
사전 설문, 망분리와 보안(DLP, 감사로그)에 대한 기대

PRE-SURVEY

51

참가 확정자 **142명 중 51명**이 "망분리, 보안(DLP, 감사로그)"를 기대 주제로 골랐습니다.

이 챕터는 그 기대에 답하는 시간입니다. 무엇을 막을 수 있고, 무엇이 기록으로 남는지 정리합니다.



복수 선택 응답, 막대 길이는 응답 인원

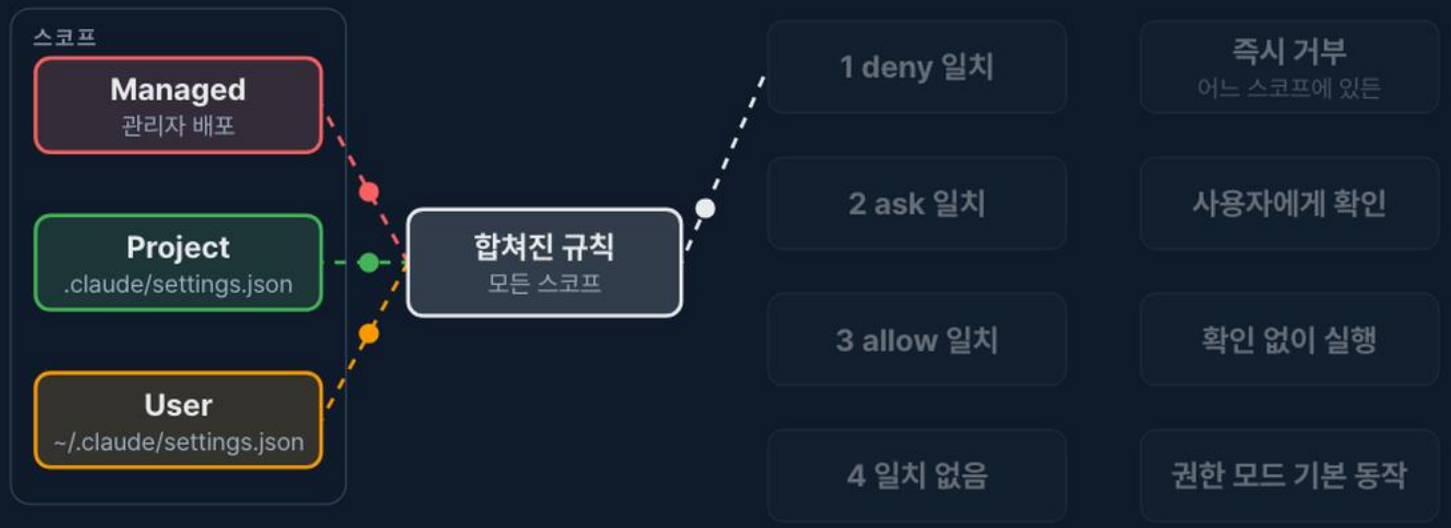
© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

deny 절대 우선

권한 평가 순서와 Tool(specifier) 규칙 문법

STEP 1 **모든 스코프를 합친 뒤 평가합니다**

규칙은 **Managed, Project, User** 등 모든 스코프에서 **합쳐진 뒤** 평가됩니다. 어느 파일에 적혔는지보다 **무엇이 적혔는지**가 결과를 정합니다.



● 거부 ● 사람 확인 ● 바로 실행 ● 다음 단계로

규칙 문법

permissions (Tool(specifier) 한 가지 형식)

```
"deny": [
  "Read(./.env)",              // 정확한 파일
  "Read(./secrets/**)",        // gitignore
스타일 글롭
  "Bash(curl *)",              // 명령 패턴
  "WebFetch(domain:pastebin.com)",
  "mcp__untrusted-server"      // MCP 서버 전체
],
"ask":   ["Bash(git push *)"],
"allow": ["Bash(npm run test *)"]
```

형식은 **Tool(specifier)** 하나입니다. 다음 단계부터 평가 순서대로 봅니다.

- 스코프별 규칙이 한 목록으로 합쳐짐
- 평가는 deny, ask, allow 순서
- 어디에 있든 deny에 걸리면 거부

‹ 1 / 5 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

user allow, managed deny라면?

QUICK CHECK, 손을 들어 답해 주세요

user settings에 allow "Bash(curl *)", managed에 deny "Bash(curl *)". 결과는?

A 그대로 실행

B 확인 후 실행

C 거부

D 나중 설정이 이김

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

앞 층이 놓친 것은 다음 층에서

DLP 5층과 층마다의 설정

OVERVIEW **다섯 층이 차례로 좁힙니다**

한 층으로 다 막을 수는 없습니다. **각 층은 앞 층이 놓친 것**을 잡습니다. 1, 2, 3, 5층은 PC에서, 4층 Guardrails는 **AWS 쪽**에서 동작합니다.



● PC 쪽 층 ● AWS 쪽 층 ● 그 층이 막는 것 ● 앞 층이 놓친 것

다섯 층과 대표 설정

1 권한 규칙	permissions.deny
2 샌드박스	sandbox.network
3 훅	PreToolUse
4 Guardrails	X-Amzn-Bedrock-*
5 반출 채널	managed allowlist

아래 화살표로 한 층씩 보겠습니다.

- 1 권한 규칙: 민감 파일, 위험 명령
- 2 샌드박스: Bash의 파일, 네트워크 격리
- 3 훅: 프롬프트, 도구 인자 패턴 검사 예제
- 4 Guardrails: 모델로 가는 PII(개인 식별 정보) 필터
- 5 반출 채널: 웹, MCP, 플러그인, mod

‹ 1 / 6 ›

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

차단은 exit 2뿐

3층 DLP 훅 예제와 fail-open, 그리고 수정본

CASE 1 **민감 패턴이 없으면 통과합니다**

패턴이 없으면 **exit 0**으로 통과합니다.
검사 대상은 **.prompt**(UserPromptSubmit) 또는 **.tool_input**(PreToolUse)입니다.



● 입력 ● 통과 ● 차단 ● 검사 실패

/opt/dlp/dlp-guard.sh

예제 (5층 중 3층)

```
#!/bin/bash
INPUT=$(cat)
TEXT=$(echo "$INPUT" | jq -r '.prompt // (.tool_input
| tostring)')
# 주민등록번호, 카드번호, AWS 액세스 키 (탐지 예시)
PAT='[0-9]{6}-[1-4][0-9]{6}|[0-9]{4}-[0-9]{4}-[0-9]{4}-[0-
9]{4}|AKIA[0-9A-Z]{16}'
if echo "$TEXT" | grep -Eq "$PAT"; then
  echo "DLP: 민감정보 패턴이 감지되어 차단했습니다" >&2
  exit 2   # 차단 (사유: UserPromptSubmit은 사용자, PreToolUse
는 Claude)
fi
exit 0
```

훅은 표준 입력으로 JSON을 받습니다.

- UserPromptSubmit은 .prompt 검사
- PreToolUse는 .tool_input 검사
- 탐지 예시일 뿐, 운영 룰은 사내 DLP 기준

‹ 1 / 4 ›

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

jq 없이 exit 127이면?

QUICK CHECK, 손을 들어 답해 주세요

DLP 훅이 jq 미설치로 exit 127로 끝나면 어떻게 될까요?

A 차단된다

B 통과된다

C 세션이 종료된다

D 자동 재시도

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

감사 근거가 남는 네 곳

무엇이 기록으로 남는가, 그리고 주의할 것

남는 것

- PC: 세션 JSONL
  cleanupPeriodDays로 보존 기간
- AWS: CloudTrail의 Bedrock 호출 이력
- AWS: Bedrock model invocation logging
  선택, 프롬프트 원문 포함
- OTel: 사용자별 토큰, 비용, 도구
  Ch6

주의할 것

- invocation logging은 원문이 저장되므로 저장소, 보존 정책 필요
- Anthropic으로 가는 텔레메트리는 Bedrock에서 기본 꺼짐
  단, WebFetch 사전 검사는 호스트명을 api.anthropic.com으로 보냄 (skipWebFetchPreflight로 끔)
- ZDR은 AWS 계약 조건에 따름
- 세션 로그도 고객 데이터를 담을 수 있음

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

더 깊은 내용은 실습에서 손으로

강의에서 줄인 주제와 실습 TASK

Lab 1 TASK 01	지금의 연결 읽기: env, 추론 프로필, 최소 IAM 정책과 비교	IAM 세부
Lab 1 TASK 02부터 04	정책 배포, 개인 설정으로 우회 시도, 정책 파일이 깨지면?	정책 배포
Lab 1 TASK 06	같은 정책을 게이트웨이 그룹 정책으로 내려보내기	게이트웨이
Lab 2 TASK 01, 02	DLP 훅을 정책으로 강제하고, fail-open을 고치기	훅
Lab 2 TASK 03	auto mode로 확인 창을 줄이고 경계 긋기	auto mode
Lab 2 선택 TASK	샌드박스로 curl 빈틈 막기, Bedrock Guardrails, 확장 통제	DLP 층

망분리 준비물, OS별 차이, 쿼터는 PDF 강의자료(정책편, 가드레일편)의 더 알아보기에 있습니다.

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

기억할 여섯 줄

Chapter 2 Key Takeaways

01

CLAUDE_CODE_USE_BEDROCK + 리전이면 연결 완료

02

장기 키 대신 SSO 프로필 + awsAuthRefresh

03

모델은 반드시 고정, 팀별 비용은 프로필 ARN으로

04

정책은 managed-settings.json, 충돌하면 managed가 이기고 /status로 확인

05

권한은 deny가 먼저, 훅은 exit 2만 차단하니 오류 경로도 exit 2로

06

네이티브 DLP는 없다, 다섯 겹을 쌓고 못 막은 것은 기록으로

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank You

다음은 점심입니다. 식사 후 통합 랩에서 Preflight와 Ch1 Lab을 마친 뒤, 오늘 본 정책과 훅을 Ch2 Lab 1, Lab 2에서 직접 배포하고 뚫어 봅니다. 질문은 Slack #20261116-claude-code-workshop-for-fsi 채널에서 언제든 받습니다.

← 목차로 돌아가기 Chapter 3 →

aws © 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved.